

MASTERPLAN EXECUTIVO E CIENTÍFICO

AAPEX / AACE V2.0

Programa de Excelência da Claro Empresas - Regional Paraná e Santa Catarina - Canal AACE

Implantação corporativa • Piloto em uma unidade • Governança, engenharia e avaliação científica

22 de julho de 2026

Versão: 2.0 - Baseline executiva e científica **Status:** proposta estruturada para validação; não constitui autorização de produção **Escopo:** implantação corporativa com piloto inicial em uma unidade **Perfis com login no piloto:** Administrador, Regional, Coordenadores e Gerentes de Canal (GCs) **Classificação sugerida:** uso interno / confidencial, conforme política corporativa

***Nota de governança.** Este documento converte o Plano Master v1.0 e a Auditoria Técnica Preliminar em uma especificação executiva, operacional, científica e técnica. Ele separa decisões confirmadas, recomendações e pontos que ainda exigem aprovação formal. Nenhum código, repositório, dependência, branch ou ambiente de produção é alterado por este Masterplan.*

Controle do documento

Campo	Definição
Produto / programa	AAPEX - Programa de Excelência; aplicativo AACE Excelência Mobile
Unidade organizacional	Claro Empresas - Regional Paraná e Santa Catarina - Canal AACE
Finalidade	Planejar implantação corporativa segura, mensurável e escalável
Escala inicial	Uma unidade piloto
Horizonte	Construção, homologação, piloto de 12 semanas e decisão de escala
Fonte funcional primária	AAPEX - Plano Master v1.0
Fonte técnica primária	Auditoria Técnica Preliminar AACE V2
Critério de precedência	Decisão corporativa formal > este Masterplan > auditoria preliminar > protótipo demonstrativo
Proprietário funcional proposto	Área de negócio designada pela Regional
Proprietário técnico proposto	Responsável técnico designado pela organização
Aprovações necessárias	Negócio, Segurança da Informação, Privacidade/DPO, Tecnologia e patrocinador executivo

Histórico de versões

Versão	Data	Natureza	Situação
1.0	2026	Sumário preliminar de uma página	Fonte de intenção
Auditoria V2	2026	Diagnóstico do código e riscos	Fonte técnica preliminar
2.0	22/07/2026	Masterplan executivo e científico	Presente documento

Regra de interpretação

- Decisão confirmada** é requisito adotado explicitamente pela responsável ou pelo patrocinador.
- Recomendação** é solução proposta com justificativa técnica, sujeita a gate de aprovação.
- Hipótese do piloto** é afirmação testável, não promessa de resultado.
- Critério de aceite** é limiar proposto para decidir se a solução está apta a avançar.
- Pendência corporativa** é tema que não pode ser resolvido apenas pelo desenvolvimento, como base legal, política de retenção, identidade corporativa ou contratação de fornecedor.

Decisões de baseline incorporadas

ID	Decisão	Estado
D-01	O objetivo do Masterplan é orientar uma implantação corporativa.	Confirmada
D-02	O piloto inicial ocorrerá em uma unidade.	Confirmada
D-03	Terão login: Administrador, Regional, Coordenadores e GCs.	Confirmada
D-04	Administrador e Regional são perfis distintos: o primeiro governa configuração; o segundo exerce visão gerencial regional.	Decorrencia lógica de D-03
D-05	Somente Administrador inclui ou inativa indicadores avaliados. Indicadores já utilizados não podem ser apagados fisicamente.	Confirmada
D-06	Parceiros/operações não terão login no piloto, salvo mudança formal de escopo.	Decorrencia de D-03
D-07	O aplicativo atual será evoluído por refatoração profunda da camada de dados, preservando componentes e telas úteis.	Recomendação executiva
D-08	A arquitetura de referência será Expo + Supabase + Vercel, condicionada à aprovação de Segurança, Privacidade e Compras.	Recomendação executiva

Sumário

- Controle do documento
- Sumário executivo
- 1. Origem, contexto e propósito
- 2. Definição do problema e proposta de valor
- 3. Escopo, não escopo e pressupostos
- 4. Governança e modelo decisório
- 5. Perfis, escopos e matriz de permissões
- 6. Modelo operacional e calendário
- 7. Requisitos funcionais por módulo
- 8. Indicadores, pontuação, versionamento e ética analítica
- 9. Diagnóstico técnico do estado atual e estratégia de transição
- 10. Arquitetura-alvo de referência
- 11. Modelo de dados e integridade histórica
- 12. Offline-first, sincronização e conflitos
- 13. Segurança da informação e engenharia segura
- 14. LGPD, privacidade e ciclo de vida dos dados
- 15. Trilha de auditoria, observabilidade e qualidade de dados
- 16. Acessibilidade, usabilidade e experiência de campo
- 17. Estratégia de testes e homologação
- 18. DevSecOps, releases e manutenção
- 19. Continuidade, backup e recuperação
- 20. Desenho científico do piloto
- 21. Hipóteses, métricas e critérios de sucesso
- 22. Plano de análise e rigor metodológico
- 23. Treinamento, gestão da mudança e suporte
- 24. Plano de implementação por fases
- 25. Custos, capacidade e sustentabilidade
- 26. Registro de riscos
- 27. Roadmap de produto e escala
- 28. Decisões pendentes para aprovação corporativa
- 29. Recomendação executiva final
- Anexos A-K

Sumário executivo

O AAPEX pretende transformar visitas, auditorias, diagnósticos, metas, planos de ação, boas práticas, rankings, relatórios e histórico em um sistema único de gestão da excelência. O propósito original é padronizar visitas, gerar diagnósticos acionáveis e acompanhar a evolução dos parceiros. A rotina informada combina visita semanal às terças-feiras e auditoria mensal na primeira segunda-feira. Esses elementos são preservados como núcleo funcional, mas deixam de ser apenas uma lista de funcionalidades para se tornar um modelo operacional verificável.

A auditoria do aplicativo existente concluiu que há valor significativo na interface, nas regras de cálculo, nos catálogos iniciais e na organização do código. O protótipo já demonstra checklist, semáforo, nota ponderada, evidências, validação, gestão assistida, planos de ação, agenda e dashboard. Entretanto, login, dados, persistência e multiusuário são demonstrativos: existe senha única no código, os dados residem em um JSON local, as evidências apontam para arquivos do dispositivo e as permissões são aplicadas apenas na interface. Assim, o produto atual é uma prova de conceito funcional, não uma plataforma corporativa.

Este Masterplan recomenda **refatoração de arquitetura**, não reconstrução integral. O front-end Expo/React Native e a identidade visual são preservados; a camada de dados, autenticação, autorização, evidências e histórico é substituída por uma base central com controles no servidor. A referência proposta é PostgreSQL, autenticação e storage via Supabase, políticas de Row Level Security (RLS), aplicação web na Vercel e aplicativo móvel Expo SDK 57. A recomendação se apoia na natureza relacional do domínio: usuários pertencem a escopos; operações são vinculadas a coordenadores e GCs; avaliações dependem de versões de templates; indicadores e metas precisam de histórico; rankings e consolidações exigem consultas consistentes.

O princípio arquitetural central é simples: **o cliente não decide sozinho o que o usuário pode acessar**. A interface pode ocultar opções, mas a autorização verdadeira deve ser aplicada no banco e nos serviços. Cada consulta e mutação deve respeitar perfil, escopo regional, unidade, operação e vínculo ativo. Chaves administrativas não podem existir no aplicativo. Registros finalizados tornam-se imutáveis; correções posteriores são adendos com autoria, motivo, data e rastreabilidade.

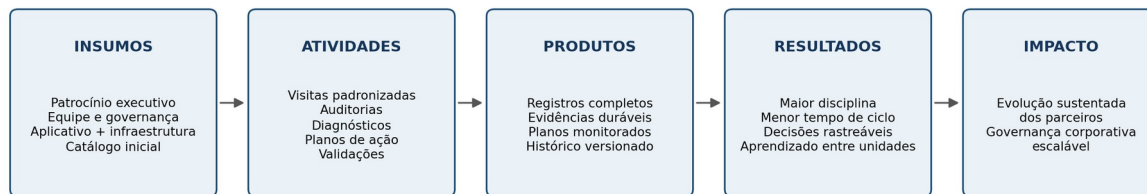
O piloto é definido como estudo prospectivo, longitudinal, de implementação em um único local, com métodos quantitativos e qualitativos. Ele não deve ser apresentado como experimento causal definitivo. Seu objetivo é avaliar viabilidade, segurança, adoção, qualidade de dados, usabilidade e sinais de melhoria operacional. O desenho recomendado utiliza duas semanas de baseline, oito semanas de operação e duas semanas de consolidação. A análise combina taxas, medianas, intervalos de confiança quando aplicáveis, run charts, comparação pré/pós e entrevistas semiestruturadas. O relatório deve distinguir resultado observado, interpretação e limitação.

Os critérios obrigatórios de avanço incluem: zero falha crítica de autorização; autenticação individual; trilha de auditoria; imutabilidade de avaliações aprovadas; restauração de backup testada; sincronização confiável; ausência de incidente grave de privacidade; e aprovação formal de Negócio, Segurança e Privacidade. Critérios de efetividade propostos incluem adoção semanal de pelo menos 85% dos usuários elegíveis, pelo menos 95% de completude dos campos obrigatórios, pelo menos 90% das visitas previstas concluídas no prazo, mediana de usabilidade SUS igual ou superior a 75 e redução operacional mensurável em retrabalho ou tempo de consolidação. Esses limiares são propostos e devem ser aprovados antes do início da coleta.

A governança evita que rankings e indicadores se convertam em mecanismos de constrangimento. No piloto, rankings individuais públicos ficam proibidos. Comparações nominais, caso necessárias, ficam restritas à cadeia gerencial, acompanhadas de contexto, tamanho mínimo de grupo e vedação de decisão automática punitiva. Boas práticas passam por moderação. O sistema existe para aprendizagem e melhoria contínua, não para exposição indevida.

O plano divide a execução em gates. O Gate 0 aprova escopo, responsáveis e arquitetura. O Gate 1 aprova modelo de dados e privacidade. O Gate 2 aprova autenticação, RLS e base técnica. O Gate 3 homologa funcionalidades e migração. O Gate 4 autoriza o piloto. O Gate 5 decide corrigir, repetir, escalar ou encerrar. Essa estrutura impede que um aplicativo visualmente pronto seja confundido com um produto corporativo seguro.

Recomendação executiva: aprovar este Masterplan como baseline, abrir um ciclo curto de decisões corporativas pendentes e somente então iniciar implementação por fases. O piloto deve ser tratado como instrumento de aprendizagem controlada, com escopo congelado, suporte próximo e critérios de interrupção claros.

Teoria de mudança do programa AAPEX/AACE

Hipótese central: padronização + dados confiáveis + responsabilização ética → melhoria contínua mensurável

Teoria de mudança do programa

1. Origem, contexto e propósito

1.1 Origem documental

O documento AAPEX - Plano Master v1.0 estabelece sete ideias fundadoras: padronização de visitas; geração de diagnósticos; planos de ação; evolução de parceiros; governança por Administrador, Coordenadores e GCs; rotina semanal e mensal; e funcionalidades de dashboard, metas, indicadores configuráveis, boas práticas, rankings, relatórios e histórico. Também exige LGPD, ética, autenticação individual, RBAC, criptografia, trilha de auditoria, backups e versionamento.

A auditoria técnica posterior mostrou que parte relevante da experiência já está desenhada e funciona localmente, mas que os requisitos corporativos centrais ainda não existem. A distância entre intenção e implementação não é uma falha de design visual; é uma lacuna de arquitetura e governança. O Masterplan parte desse diagnóstico para definir o caminho de transição entre protótipo e produto.

1.2 Propósito do programa

O propósito operacional é criar um ciclo contínuo e rastreável:

6. planejar a visita;
7. observar a operação segundo critérios padronizados;
8. registrar resultado e evidência;
9. diagnosticar causas;
10. pactuar ações, responsáveis e prazos;
11. validar o registro;
12. acompanhar a execução;
13. comparar evolução sem apagar o contexto histórico;
14. disseminar boas práticas aprovadas.

O propósito gerencial é produzir uma visão confiável da qualidade da execução, permitindo que GCs atuem com foco, coordenadores removam impedimentos e a Regional identifique padrões sistêmicos. O sistema deve reduzir planilhas paralelas, mensagens dispersas, evidências perdidas e decisões baseadas em versões divergentes.

1.3 Princípios estruturantes

- **Verdade histórica:** registros aprovados não são reescritos silenciosamente.
- **Menor privilégio:** cada perfil acessa somente o necessário ao seu papel e escopo.
- **Dados antes de ranking:** comparações só são válidas após qualidade, contexto e estabilidade do instrumento.
- **Ação antes de estética:** um indicador vermelho deve produzir diagnóstico e plano, não apenas cor.
- **Offline controlado:** ausência de conexão permite trabalhar em rascunho, mas não cria múltiplas verdades.
- **Privacidade por padrão:** evidências devem evitar dados de clientes finais e informações desnecessárias.
- **Explicabilidade:** notas, metas, semáforos e consolidações devem ter fórmulas documentadas.
- **Proporcionalidade:** arquitetura e controles devem ser fortes sem criar manutenção incompatível com 20-25 usuários iniciais.
- **Evolução por evidência:** novas funções entram por gates, testes e dados do piloto.

1.4 Resultado esperado

Ao final do piloto, a organização deve saber, com evidência suficiente:

- se os usuários conseguem executar o fluxo no ambiente real;
- se dados e evidências permanecem íntegros entre dispositivos;
- se permissões impedem acesso indevido;
- se a rotina é aderente ao trabalho de campo;
- se a informação melhora o acompanhamento de ações;
- qual esforço de suporte e capacitação será necessário para escalar;
- quais módulos devem ser corrigidos, adiados ou ampliados.

2. Definição do problema e proposta de valor

2.1 Problema operacional

Sem uma plataforma central, uma rotina de visitas tende a fragmentar-se em agendas individuais, planilhas, fotografias no aparelho, mensagens, apresentações e memória informal. Mesmo quando cada parte é bem executada, surgem problemas de versão, completude, comparabilidade e rastreabilidade. A nota final pode existir sem ser possível reconstruir por que foi atribuída; um plano pode ser criado sem acompanhamento; uma evidência pode desaparecer; e um indicador pode mudar de definição sem preservar comparabilidade.

O problema não é apenas “digitalizar formulários”. É estabelecer uma cadeia de custódia gerencial para decisões: quem observou, com qual versão do critério, em qual operação, com qual evidência, quem validou, qual ação foi acordada e o que ocorreu depois.

2.2 Proposta de valor por perfil

Perfil	Valor principal	Decisão apoiada
GC	Roteiro único de visita, registro simples, memória da visita anterior e agenda de ações	Onde atuar hoje e o que acompanhar na próxima visita
Coordenador	Fila de validação, visão das operações e acompanhamento de planos	Onde orientar, devolver, escalar ou reconhecer
Regional	Consolidação temporal e territorial, tendências e riscos sistêmicos	Quais temas exigem intervenção regional
Administrador	Governança de cadastros, templates, indicadores, usuários e versões	Como manter o sistema coerente e auditável
Patrocinador	Evidência de adoção, resultado e risco	Escalar, corrigir, investir ou interromper

2.3 O que a solução não deve se tornar

O sistema não deve funcionar como vigilância indiscriminada, repositório de dados de clientes finais, mecanismo de punição automática, mural de exposição individual ou substituto da gestão humana. Também não deve permitir que a facilidade de alterar configurações destrua a comparabilidade histórica. Qualquer função de ranking ou avaliação de pessoas deve observar finalidade, necessidade, contexto e revisão humana.

2.4 Teoria de mudança

A teoria de mudança é: se a organização oferecer critérios claros, captura simples, evidência durável, validação independente, planos monitorados e consolidação contextual, então aumentará a qualidade e a tempestividade dos registros; com registros confiáveis, gestores poderão direcionar ações e aprender entre operações; com ações acompanhadas, espera-se melhoria gradual dos indicadores e da execução.

Essa cadeia contém premissas que o piloto deve testar: disponibilidade de tempo, qualidade dos indicadores, conectividade, compreensão dos usuários, apoio gerencial, estabilidade das metas e uso ético dos resultados. Se uma dessas premissas falhar, a tecnologia isolada não produz o impacto esperado.

3. Escopo, não escopo e pressupostos

3.1 Escopo funcional do piloto

O piloto incluirá:

- autenticação individual dos quatro perfis;
- cadastro e ativação/inativação de usuários e vínculos;
- cadastro de unidade, operações e atribuições;
- agenda baseada em regras configuráveis;
- visita semanal e auditoria mensal;
- checklist versionado com pontuação ponderada;
- indicadores de desempenho com meta, realizado e semáforo;
- evidências privadas em nuvem;
- diagnóstico e plano de ação;
- submissão, devolução e aprovação;
- histórico por operação e por ciclo;
- dashboard por escopo;
- trilha de auditoria;
- exportação gerencial básica;
- operação em rascunho com conectividade limitada e sincronização posterior;
- monitoramento de adoção, erros e desempenho.

3.2 Escopo diferido

Ficam fora do piloto, salvo aprovação de mudança:

- login de parceiros ou operações;
- integração com sistemas corporativos de CRM, RH ou BI;
- inteligência artificial preditiva;
- recomendação automática de sanção ou avaliação laboral;
- ranking individual público;
- edição livre de fórmulas por usuários de negócio;
- workflow jurídico de titulares de dados dentro do aplicativo;
- geolocalização contínua;
- gravação de áudio ou vídeo;
- migração massiva de dados reais legados;
- publicação em lojas públicas sem MDM ou governança definida;
- automações que enviem mensagens externas em nome da empresa sem aprovação.

3.3 Pressupostos

15. A unidade piloto terá patrocínio local e um coordenador responsável.
16. O conjunto atual de 24 temas e 12 indicadores será usado apenas como seed até validação do conteúdo.
17. Não existem dados reais indispensáveis no protótipo que exijam migração; se existirem, haverá plano específico.
18. A conectividade pode oscilar, mas haverá ao menos uma janela diária de sincronização.
19. Usuários utilizarão contas individuais e não compartilharão credenciais.
20. A política corporativa definirá identidade, provedor, região de dados e contratação.
21. Evidências não devem conter dados de clientes finais por padrão.
22. A rotina de terça-feira e primeira segunda-feira pode ser parametrizada para feriados e exceções.

3.4 Controle de mudança de escopo

Mudanças são registradas em solicitação contendo problema, benefício, risco, impacto em prazo, dados, segurança, testes e treinamento. Durante o piloto, somente correções críticas, segurança, integridade de dados ou bloqueios operacionais entram imediatamente. Melhorias cosméticas e novas funções vão para backlog pós-piloto. Essa disciplina protege a interpretação científica: se o instrumento muda continuamente, não se sabe se o resultado decorre do processo ou da alteração do sistema.

4. Governança e modelo decisório

4.1 Estrutura proposta

Fórum / papel	Responsabilidade	Cadência
Patrocinador executivo	Aprovar escopo, recursos e decisão de escala	Gates e mensal
Comitê AAPEX	Negócio, Regional, Tecnologia, Segurança, Privacidade e Produto	Quinzenal na construção; semanal no piloto
Product Owner	Priorizar backlog, validar regras e representar usuários	Contínua
Responsável técnico	Arquitetura, qualidade, releases e incidentes técnicos	Contínua
Administrador funcional	Cadastros, versões e suporte de primeiro nível	Conforme necessidade
Regional	Uso gerencial, remoção de impedimentos e leitura consolidada	Semanal
Coordenador piloto	Validação, coaching e supervisão local	Diária/semanal
DPO/Privacidade	Finalidade, dados, retenção, contratos e incidentes	Gates e incidentes
Segurança da Informação	Riscos, arquitetura, testes e resposta	Gates e incidentes

4.2 Separação entre cargo e permissão

“Administrador” é uma permissão funcional, não sinônimo necessário de Gerente Regional. O perfil Regional tem poder de leitura e gestão regional, mas não altera livremente definições estruturais. Essa separação reduz risco de mudança acidental, concentra governança e cria trilha clara. Uma mesma pessoa pode acumular perfis apenas se houver justificativa e aprovação; o sistema deve registrar os perfis separadamente.

4.3 Gates de decisão

Gate	Pergunta	Evidências mínimas	Saída possível
G0 - Baseline	Escopo e responsáveis estão aprovados?	Masterplan, RACI, decisões pendentes	Aprovar / revisar
G1 - Dados e privacidade	O modelo trata apenas dados necessários e possui base/política?	inventário, fluxo, retenção, DPA	Aprovar / bloquear
G2 - Fundação técnica	Auth, RLS, logs e backup funcionam?	testes automatizados e relatório de segurança	avançar / corrigir
G3 - Homologação	Fluxos funcionais e offline estão aptos?	UAT, testes E2E, restauração	autorizar piloto / rejeitar
G4 - Entrada no piloto	Unidade, usuários, suporte e baseline estão prontos?	cadastro, treinamento, plano de suporte	iniciar / adiar
G5 - Decisão de escala	Benefícios superam riscos e custos?	relatório científico e executivo	escalar / repetir / corrigir / encerrar

4.4 Registro de decisões

Decisões arquiteturais e funcionais relevantes devem ser registradas como ADRs - Architecture Decision Records - contendo contexto, opções, decisão, consequência, data e aprovadores. Isso evita que escolhas críticas fiquem escondidas em conversas ou commits. O Anexo H fornece o modelo.

5. Perfis, escopos e matriz de permissões

5.1 Modelo de autorização

O controle combina RBAC e escopo. RBAC define **o que** o perfil pode fazer; o escopo define **sobre quais dados**. Um Coordenador pode validar avaliações, mas somente das operações sob sua responsabilidade. Um GC pode criar visitas, mas somente para operações às quais está vinculado. O Regional lê a região; o Administrador configura o ambiente autorizado.

A autorização deve ocorrer no servidor, por políticas de banco e funções controladas. A interface repete as regras para melhorar usabilidade, mas não é barreira de segurança. As políticas devem negar por padrão e liberar explicitamente.

5.2 Permissões resumidas

Ação	Administrador	Regional	Coordenador	GC
Gerenciar usuários e vínculos	Sim	Solicita/consulta	Não	Não
Criar/inativar indicador	Sim	Não	Não	Não
Alterar template futuro	Sim	Consulta	Propõe	Não
Ver toda a região	Conforme escopo	Sim	Não	Não
Ver operações atribuídas	Sim	Sim	Sim	Sim
Criar visita	Excepcional	Não	Opcional, se autorizado	Sim
Enviar avaliação	Se autor da visita	Não	Se autor da visita	Sim
Aprovar avaliação de GC	Não por rotina	Escalação	Sim	Não
Aprovar o próprio registro	Não	Não	Não	Não
Criar/atribuir plano	Sim	Sim	Sim	Sim, dentro da visita
Alterar registro aprovado	Não; apenas adendo	Não	Não	Não
Publicar boa prática	Administra	Consulta	Modera/aprova	Propõe
Ver ranking nominal	Configurável/restrito	Restrito	Somente equipe própria	Não no piloto
Exportar dados	Controlado	Consolidado	Escopo próprio	Próprios registros
Ver trilha de auditoria	Sim	Leitura gerencial	Eventos do escopo	Próprias ações

5.3 Regras de segregação

- Ninguém aprova a própria submissão.
- Atribuição de perfil privilegiado exige segundo aprovador ou registro formal.
- Exclusão de usuário é inativação; histórico permanece associado.
- Mudança de vínculo não transfere autoria nem altera registros passados.
- Administrador não pode editar silenciosamente avaliações finalizadas.
- Exportações contêm marca d'água lógica: usuário, data, escopo e finalidade.
- Acesso emergencial, se existir, tem prazo, justificativa e alerta.

5.4 Ciclo de vida do acesso

23. solicitação formal;
24. validação de identidade e vínculo;
25. concessão do menor perfil necessário;
26. primeiro acesso com troca/definição segura de credencial;
27. MFA conforme política;
28. revisão periódica de acesso;
29. suspensão imediata em desligamento ou mudança de função;
30. preservação de autoria histórica;
31. registro de toda concessão, alteração e revogação.

6. Modelo operacional e calendário

6.1 Rotina padrão

A rotina original estabelece visita semanal às terças-feiras e auditoria mensal na primeira segunda-feira. O sistema deve transformar essa intenção em regra configurável, não data fixa. Cada unidade terá calendário, fuso, feriados, exceções, responsáveis e janela de tolerância.

Visita semanal

- criada automaticamente ou sugerida pelo calendário;
- atribuída ao GC responsável;
- recupera pendências e evolução da visita anterior;
- permite indicadores e diagnóstico da semana;
- gera ou atualiza planos de ação;
- deve ser enviada até a janela definida;
- passa por validação do Coordenador quando configurado.

Auditoria mensal

- usa template versionado vigente na data de abertura;
- exige todos os itens obrigatórios;
- exige evidência por tema conforme regra;
- exige plano de ação para item vermelho;
- calcula nota ponderada de forma determinística;
- após aprovação, gera snapshot oficial do mês.

6.2 Exceções de calendário

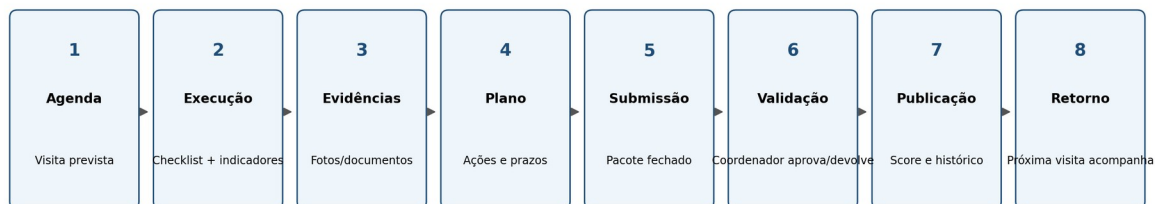
Feriados, afastamentos, indisponibilidade da operação e mudança de responsável não podem ser resolvidos apagando a obrigação. O evento recebe estado e motivo: reprogramado, cancelado justificado, não realizado ou realizado fora do prazo. A métrica de aderência distingue atraso de cancelamento legítimo.

6.3 Estados principais

Objeto	Estados
Visita	prevista, em rascunho, pronta para envio, enviada, devolvida, aprovada, cancelada
Avaliação	rascunho, submetida, devolvida, aprovada, supersedida por adendo
Plano de ação	aberto, em andamento, bloqueado, concluído, vencido, cancelado justificado
Evidência	local pendente, enviando, armazenada, falha, expirada por retenção
Indicador	rascunho, ativo, inativo; versões nunca são apagadas se usadas
Usuário	convidado, ativo, suspenso, inativo

6.4 SLA operacional proposto

- validação de submissão: até 2 dias úteis;
- correção de devolução: até 2 dias úteis, salvo justificativa;
- ação crítica vencida: alerta no primeiro dia útil;
- incidente técnico crítico: triagem imediata e comunicação interna em até 1 hora;
- pedido de acesso: conforme fluxo corporativo;
- sincronização pendente: alerta ao usuário após 4 horas e à equipe após 24 horas.

Fluxo operacional e de validação

Devolução gera nova versão do rascunho; aprovação torna a avaliação imutável. Correções posteriores ocorrem por adendo auditável.

Fluxo operacional

7. Requisitos funcionais por módulo

7.1 Autenticação e perfil

O login deve ser individual, sem senha compartilhada ou credencial no código. A solução deve priorizar SSO corporativo se disponível; caso contrário, usar e-mail aprovado, senha robusta, recuperação controlada e MFA conforme risco. O perfil mostra função, escopo, último acesso, versão do aplicativo e canais de suporte. Nenhuma senha de demonstração pode aparecer na interface.

7.2 Dashboard

O dashboard apresenta apenas métricas autorizadas e calculadas sobre dados aprovados. Deve separar rascunhos de resultados oficiais, indicar período, universo e atualização. Métricas mínimas: visitas previstas/realizadas, auditorias aprovadas, nota média, itens críticos, planos abertos/vencidos, validações pendentes e tendência. Toda métrica possui definição acessível.

7.3 Agenda

A agenda combina visitas, auditorias, planos e devoluções. Deve oferecer hoje, 7 e 30 dias, filtros por operação e responsável e distinção entre obrigação e lembrete. A geração de eventos deriva das regras de calendário; datas não podem ser hardcoded.

7.4 Auditoria

O checklist conserva os 24 temas atuais como seed. Cada item possui versão, peso, obrigatoriedade, tipo de resposta, regra de semáforo e exigência de evidência. O envio só ocorre com completude total dos obrigatórios. A nota deve ser reproduzível no servidor e no cliente; divergência bloqueia aprovação.

7.5 Gestão assistida

Os 12 indicadores atuais são seed. Cada indicador possui unidade, direção desejada, meta, faixa de semáforo, periodicidade, fonte, responsável, versão e data de vigência. Meta e realizado não podem ser confundidos. O relatório recupera a visita anterior e destaca mudança real, não fórmula fictícia.

7.6 Diagnóstico

Chips ou categorias podem acelerar preenchimento, mas não devem reduzir causa a rótulo obrigatório. O diagnóstico mínimo contém achado, causa provável, impacto e evidência. Campos livres têm limite e orientação. Categorias são versionadas para permitir análise sem destruir significado histórico.

7.7 Planos de ação

Cada ação deve conter descrição verificável, responsável, prazo, prioridade, origem, critério de conclusão e atualizações. A conclusão exige evidência ou justificativa. Reabertura preserva o encerramento anterior. Ações críticas não podem ser apagadas; cancelamento exige motivo e aprovação conforme regra.

7.8 Validações

O validador vê conteúdo, evidências, regras e histórico de devoluções. Aprovar produz snapshot oficial. Devolver exige motivo estruturado e comentário. A fila é priorizada por atraso, criticidade e data. Aprovação em lote de avaliações complexas fica proibida no piloto.

7.9 Boas práticas

GCs e Coordenadores podem propor práticas com problema, contexto, ação, evidência de resultado e condições de replicação. O Coordenador modera; o Administrador governa categorias. Antes de publicar, remover dados pessoais e informações sensíveis. Popularidade não substitui validação.

7.10 Relatórios e exportação

Relatórios devem existir em tela e em formato exportável controlado. O piloto prevê: relatório de visita, auditoria mensal, planos de ação, evolução por operação e consolidado regional. Exportações registram autor, período, escopo e finalidade. Dados brutos completos exigem permissão específica.

8. Indicadores, pontuação, versionamento e ética analítica

8.1 Governança dos indicadores

Somente o Administrador pode incluir ou inativar indicadores avaliados. “Excluir” um indicador já usado significa impedir uso futuro, mantendo definições e medições passadas. Uma alteração substantiva - fórmula, unidade, direção, peso ou faixa - cria nova versão. Correção meramente textual pode ser classificada, mas também deve ser registrada.

8.2 Estrutura mínima da definição

Campo	Exemplo de uso
Código estável	IND-012
Nome	Nome compreensível ao usuário
Objetivo	O que o indicador pretende representar
Fórmula	Expressão e regras de arredondamento
Unidade	%, valor, quantidade, índice
Direção	maior é melhor, menor é melhor, faixa ideal
Fonte	sistema, observação, informação da operação
Periodicidade	semanal, mensal
Meta e tolerâncias	valores e vigência
Versão	número e data de vigência
Responsável	área que responde pelo conceito
Limitações	situações em que não deve ser comparado

8.3 Pontuação de auditoria

A pontuação ponderada deve ser calculada por fórmula documentada. Itens não aplicáveis só podem ser excluídos do denominador se a regra permitir e houver justificativa. O servidor recalcula a nota; o cliente exibe prévia. Pesos e faixas pertencem à versão do template. A avaliação armazena referência à versão, evitando que uma mudança futura altere nota passada.

8.4 Qualidade de medição

Antes de usar um indicador para comparar pessoas ou operações, avaliar:

- definição inequívoca;
- fonte e rastreabilidade;
- completude;
- estabilidade temporal;
- sensibilidade a manipulação;
- diferenças de contexto;
- frequência suficiente;
- concordância entre avaliadores, quando observacional.

Para itens subjetivos, o piloto deve realizar calibração: dois avaliadores aplicam parte do instrumento e discutem divergências. Quando houver volume suficiente, pode-se estimar concordância percentual e coeficiente apropriado; no piloto pequeno, o principal produto é a revisão das definições ambíguas.

8.5 Rankings

No piloto, não haverá ranking individual público. Comparações nominais ficam restritas a Regional e Coordenadores dentro do escopo e não podem gerar punição automática. Preferir faixas, evolução própria, distribuição e temas críticos. Um ranking, quando autorizado após o piloto, deve informar período, universo, critérios, empates, dados faltantes e limitações. Grupos muito pequenos não devem ser exibidos para evitar exposição e inferência.

8.6 Indicadores inteligentes

A etapa V1.4 “Indicadores Inteligentes” não significa inteligência artificial obrigatória. Primeiro, significa validações, alertas, detecção de inconsistências, tendência e recomendação baseada em regra transparente. Modelos preditivos só

devem ser considerados quando houver dados suficientes, base legal, avaliação de viés, explicabilidade e governança de modelo.

9. Diagnóstico técnico do estado atual e estratégia de transição

9.1 Ativos reaproveitáveis

O código atual é tipado, pequeno e consistente. São reaproveitáveis: componentes visuais, tema, navegação, as telas como base, regras de score e semáforo, formatação e catálogos iniciais. O build web e o deploy Vercel demonstram viabilidade do canal. O valor de reaproveitamento reduz risco de reescrever interações já compreendidas.

9.2 Componentes a substituir

Devem ser removidos do caminho de produção:

- senha única e perfis demonstrativos;
- dados fictícios e datas fixas;
- AsyncStorage como banco autoritativo;
- evidências por URI local;
- autorização apenas na interface;
- versão hardcoded;
- fórmulas que simulam histórico;
- exclusão física ou sobrescrita de definições usadas.

9.3 Estratégia strangler da camada de dados

A transição ocorrerá módulo a módulo por interfaces de repositório. Telas deixam de ler diretamente o AppContext monolítico e passam a consumir serviços de domínio: AuthRepository, VisitsRepository, IndicatorsRepository, ActionsRepository e SyncService. Durante a migração, adaptadores podem manter dados demo em ambiente exclusivo, mas o build corporativo não inclui credenciais ou atalhos de demonstração.

9.4 Migração

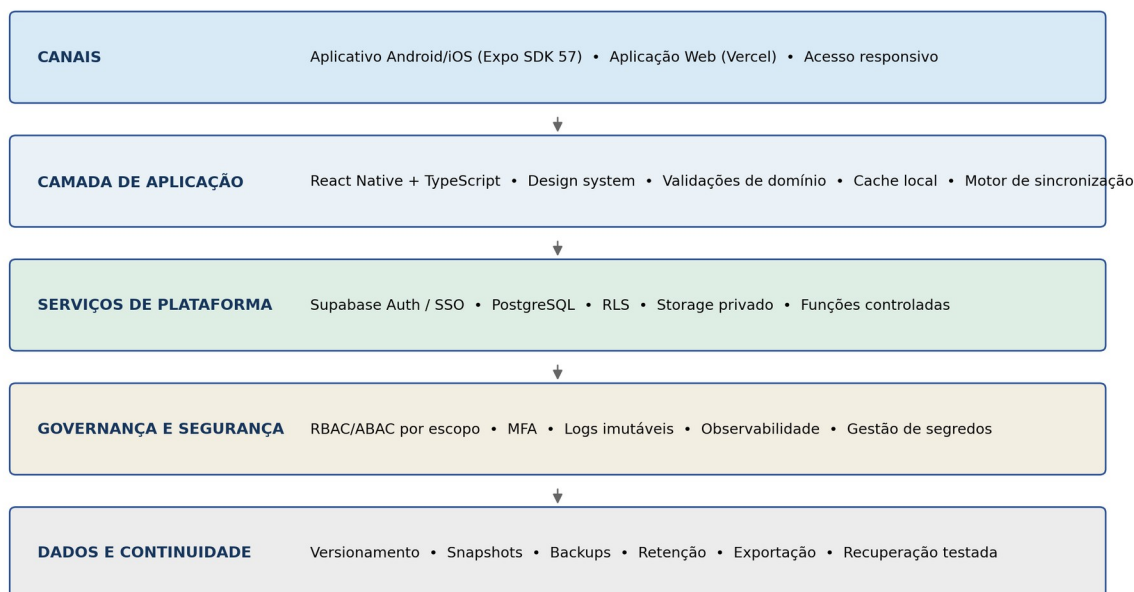
Se for confirmado que os dados atuais são fictícios, o banco é iniciado com seeds revisados e nenhum histórico é migrado. Caso apareçam dados reais, a migração exige inventário, mapeamento, limpeza, validação e aceite de negócio. Não se deve importar o JSON inteiro sem compreender origem e qualidade.

9.5 Critério de preservação da interface

Uma tela é preservada quando atende ao fluxo, acessibilidade e segurança. Reaproveitar código não é objetivo em si. Componentes que induzem erro - por exemplo, botão de perfil demonstrativo - devem ser removidos. A métrica de sucesso é risco reduzido e continuidade da experiência, não porcentagem de linhas mantidas.

10. Arquitetura-alvo de referência

Arquitetura-alvo de referência



Princípio: o cliente nunca é a autoridade final de permissão; autorização é aplicada no servidor e testada por políticas RLS.

Arquitetura-alvo

10.1 Visão

A arquitetura proposta usa um front-end único Expo/React Native para Android, iOS e web, com TypeScript. A aplicação web permanece hospedada na Vercel. O backend de referência usa Supabase: Auth para identidade, PostgreSQL para dados, RLS para autorização, Storage privado para evidências e funções controladas para operações privilegiadas. A escolha deve passar por validação corporativa de fornecedor, região, contrato, transferência internacional, continuidade e integração de identidade.

10.2 Justificativa

O domínio é relacional e histórico. PostgreSQL favorece integridade referencial, transações, consultas consolidadas, snapshots e exportações. A documentação do Supabase recomenda RLS em tabelas expostas e proíbe expor chaves de serviço no cliente [R8]. O Storage oferece controle fino por políticas e buckets privados [R9]. O Expo SDK 57 define a base móvel/web atual do projeto e deve ser consultado de forma versionada [R11].

10.3 Componentes

Cliente

- Expo SDK 57 e React Native;
- TypeScript em modo estrito;
- camada de domínio independente da UI;
- SQLite local para rascunhos, cache e outbox;
- SecureStore ou mecanismo equivalente para tokens, nunca dados completos de negócio;
- detector de conectividade;
- fila idempotente de sincronização;
- telemetria sem conteúdo sensível.

Backend

- Auth com SSO/OIDC preferencial ou e-mail corporativo;
- PostgreSQL com constraints, triggers limitadas e RLS;
- Storage privado com caminhos não previsíveis e metadados no banco;
- funções server-side para criação de usuários, exportações e processos privilegiados;

- tarefas agendadas para calendário, alertas e retenção;
- logs de auditoria append-only.

Entrega

- GitHub como repositório;
- CI com lint, typecheck, testes, análise de dependências e build;
- ambientes separados: desenvolvimento, homologação e produção;
- segredos no provedor, nunca no repositório;
- deploy de produção sujeito a aprovação.

10.4 Requisitos não funcionais

Dimensão	Meta proposta para piloto
Disponibilidade	99,5% durante janela operacional, excluídas manutenções aprovadas
Desempenho	telas principais com resposta percebida < 2 s em rede normal; operações pesadas com feedback
Sincronização	99% das mutações válidas sincronizadas em até 24 h
Integridade	zero perda de registro aprovado; checksums para evidências
Segurança	zero vulnerabilidade crítica aberta no Gate 4
Acessibilidade	WCAG 2.2 AA na web como referência e equivalência móvel
Escalabilidade	suportar ao menos 10 vezes o piloto sem redesenho estrutural
Observabilidade	erros, latência, sync e auditoria mensuráveis

10.5 Arquiteturas alternativas

Firebase continua alternativa se offline nativo extremo superar a necessidade relacional. API própria oferece controle, mas aumenta manutenção. A decisão deve comparar segurança, custo total, competência da equipe, portabilidade, região de dados e integração corporativa. A recomendação Supabase não elimina a obrigação de saída: esquema SQL versionado, exportação periódica e documentação reduzem lock-in.

11. Modelo de dados e integridade histórica

11.1 Princípios

- identificadores estáveis e não significativos;
- timestamps em UTC com exibição local;
- created_by, updated_by e origem;
- soft delete apenas quando compatível; registros oficiais não são apagados;
- versionamento de conceitos mutáveis;
- snapshots para resultados publicados;
- constraints no banco, não apenas validação da tela;
- idempotency_key para mutações offline;
- row_version para concorrência otimista.

11.2 Entidades principais

Entidade	Finalidade	Observação de integridade
organizations	organização controladora do ambiente	preparada para expansão
regions	recorte regional	PR/SC no baseline
units	unidade piloto e futuras unidades	escopo operacional
operations	parceiros/operações avaliadas	sem login no piloto
users	identidade de aplicação	vinculada ao Auth
roles	perfis	admin, regional, coordenador, GC
user_scopes	vínculo entre usuário, papel e escopo	vigência temporal
visit_rules	regras de calendário	terça, mensal, feriados
visits	instância de visita	estado e responsável
audit_templates	conceito de checklist	código estável
audit_template_versions	versão vigente	imutável após uso
audit_items	itens e pesos	vinculados à versão
evaluations	cabeçalho da avaliação	rascunho/aprovada
evaluation_answers	respostas	validações e score
indicator_definitions	identidade do indicador	ativo/inativo
indicator_versions	fórmula, unidade, faixas	vigência
measurements	meta e realizado	referência à versão
evidence_files	metadados e hash	objeto privado
diagnoses	achado, causa e impacto	origem definida
action_plans	ação, responsável, prazo	histórico de estados
validations	aprovação/devolução	sem autoaprovação
best_practices	proposta e publicação	moderação
official_snapshots	visão publicada do ciclo	não recalculada retroativamente
audit_logs	eventos de segurança e negócio	append-only
sync_operations	estado de sincronização	idempotência

11.3 Versionamento de indicadores

A tabela indicator_definitions mantém identidade e estado. indicator_versions mantém cada definição. Uma medição aponta para indicator_version_id. Inativar impede novas medições, mas consultas históricas continuam. Reativação, se permitida, cria nova versão ou registra vigência; não altera silenciosamente a anterior.

11.4 Avaliações e snapshots

Enquanto rascunho, a avaliação pode ser atualizada pelo autor. Ao enviar, recebe versão de submissão. Devolução reabre cópia controlada. Aprovação gera snapshot contendo score, respostas, versões de template, indicadores, evidências e responsáveis. Alteração posterior é adendo; o snapshot original permanece.

11.5 Evidências

O banco guarda metadados: bucket, caminho, MIME, tamanho, hash, autor, objeto de origem, data, classificação, retenção e estado de verificação. O arquivo fica em bucket privado. URLs são temporárias. Não se sobrescreve um arquivo aprovado no mesmo caminho; nova evidência recebe novo objeto.

11.6 Dicionário e catálogo

Cada campo de negócio terá definição, tipo, obrigatoriedade, origem, finalidade, perfil com acesso, retenção e qualidade esperada. O Anexo C apresenta o dicionário inicial. O dicionário é artefato vivo e obrigatório para BI.

12. Offline-first, sincronização e conflitos

12.1 Distinção essencial

“Tudo local” não é offline com sincronização. Offline-first significa que o usuário pode executar trabalho autorizado sem conexão e que, quando a rede retorna, mudanças são reconciliadas com uma verdade central segundo regras determinísticas.

12.2 Dados locais

O dispositivo armazena somente o necessário ao trabalho atual: agenda, operações atribuídas, templates vigentes, rascunhos, miniaturas e outbox. Dados locais possuem prazo, criptografia quando suportada e limpeza remota/lógica na revogação. Tokens ficam em armazenamento seguro. Não se replica toda a região para cada GC.

12.3 Outbox e idempotência

Cada ação gera operação local com UUID, usuário, dispositivo, objeto, versão esperada, payload mínimo e idempotency_key. O servidor processa uma vez. Retries usam backoff e não duplicam visitas ou ações. A interface mostra pendências e falhas de forma compreensível.

12.4 Regras de conflito

Situação	Regra
Mesmo rascunho editado no mesmo dispositivo	versão local sequencial
Mesmo rascunho em dispositivos distintos	bloquear ou exigir escolha explícita; nunca mesclar silenciosamente campos críticos
Registro já submetido	rejeitar alteração de rascunho antigo
Plano atualizado por dois usuários	concorrência otimista; usuário revisa diferença
Template mudou durante rascunho	rascunho mantém versão de abertura; novo ciclo usa nova versão
Evidência duplicada	hash e idempotência evitam repetição
Usuário perdeu escopo antes de sincronizar	servidor nega; operação vai para revisão administrativa

12.5 Evidências em rede instável

Arquivos pequenos podem usar upload padrão; arquivos maiores ou rede instável devem usar upload retomável. O Supabase oferece protocolo TUS para uploads resumíveis [R12]. O processo recomendado: reservar metadado, gerar caminho, enviar em partes, calcular hash, confirmar no servidor e só então marcar evidência como armazenada. A submissão final exige todas as evidências obrigatórias confirmadas.

12.6 Testes offline

- perda de rede antes, durante e após envio;
- encerramento do aplicativo durante upload;
- token expirado;
- mudança de perfil;
- relógio do aparelho incorreto;
- duplicação de toque;
- arquivo corrompido;
- dois dispositivos;
- atualização do aplicativo com outbox pendente;
- restauração após reinstalação, dentro do que a política permitir.

13. Segurança da informação e engenharia segura

13.1 Referenciais

A governança de risco adota as funções Govern, Identify, Protect, Detect, Respond e Recover do NIST CSF 2.0 [R3]. Requisitos técnicos de aplicação usam OWASP ASVS 5.0 como base web/backend [R4] e OWASP MASVS para mobile [R5]. A organização pode alinhar o sistema de gestão à ISO/IEC 27001:2022 [R7]. Esses referenciais não substituem política corporativa; oferecem vocabulário e cobertura.

13.2 Ameaças prioritárias

- uso de credencial compartilhada ou comprometida;
- escalada de privilégio e falha de RLS;
- exposição de chave de serviço no cliente;
- acesso a evidências por URL pública;
- exportação excessiva;
- perda ou roubo de dispositivo;
- alteração retroativa de avaliação;
- dependência vulnerável;
- phishing e recuperação de conta indevida;
- vazamento em logs e telemetria;
- indisponibilidade ou perda de backup;
- dados pessoais capturados acidentalmente em fotografias.

13.3 Controles mínimos

Identidade

- SSO corporativo preferencial;
- MFA obrigatório para Administrador, Regional e Coordenador; política para GCs aprovada antes do piloto;
- proteção contra senha vazada e tentativas abusivas;
- sessões curtas para operações privilegiadas;
- revogação e revisão de acesso.

Autorização

- RLS em todas as tabelas expostas;
- testes positivos e negativos por perfil;
- funções privilegiadas server-side;
- service role nunca enviada ao cliente;
- deny by default.

Dados

- TLS em trânsito;
- criptografia do provedor em repouso;
- buckets privados;
- URLs assinadas curtas;
- segredo fora do Git;
- logs sem payload sensível;
- backup e restauração testados.

Desenvolvimento

- revisão de pull request;
- branch protegida;
- análise estática, dependências e segredos;
- testes de segurança automatizados;
- ambientes separados;
- inventário de componentes e licenças;
- atualizações planejadas do Expo e dependências.

13.4 Critérios de severidade

- **Crítica:** acesso não autorizado entre escopos, chave privilegiada exposta, perda de dados oficiais, execução remota, evidência pública.
- **Alta:** bypass parcial, alteração indevida, recuperação de conta frágil, backup não restaurável.
- **Média:** excesso de informação, sessão longa, log inadequado, rate limit insuficiente.
- **Baixa:** hardening e melhoria sem exploração plausível imediata.

Nenhuma vulnerabilidade crítica ou alta sem mitigação aceita pode permanecer no Gate 4.

13.5 Resposta a incidentes

O playbook inclui identificação, contenção, preservação de evidência, erradicação, recuperação, avaliação de dados pessoais, comunicação interna e lições aprendidas. A ANPD prevê comunicação de incidente com risco ou dano relevante e manutenção de registros de incidentes por pelo menos cinco anos; a página oficial informa prazo de três dias úteis para comunicação aplicável [R13]. O alvo interno deve ser mais rápido: escalar suspeita em até uma hora e envolver Privacidade imediatamente.

14. LGPD, privacidade e ciclo de vida dos dados

14.1 Privacy by design

A LGPD não é um texto de tela; é um conjunto de decisões sobre finalidade, necessidade, acesso, retenção, transparência e responsabilidade. Antes do piloto, a organização deve identificar controlador, operadores e encarregado conforme sua estrutura, documentar operações de tratamento e aprovar base legal. A ANPD mantém guias de agentes de tratamento e de segurança da informação [R1][R2].

14.2 Categorias de dados previstas

- identidade e contato corporativo dos usuários;
- papel, vínculo, unidade e operação atribuída;
- registros profissionais de visitas e validações;
- imagens ou documentos de evidência;
- logs de acesso e ações;
- dados de dispositivo estritamente necessários à segurança/sync;
- comentários e diagnósticos.

O aplicativo não deve solicitar CPF, dados de saúde, localização contínua ou dados de clientes finais sem necessidade aprovada. Evidências devem ser enquadradas como “sem dados pessoais de cliente” por padrão. Se um dado aparecer incidentalmente, deve haver orientação de recorte, desfocagem ou remoção.

14.3 Inventário de tratamento

Para cada operação registrar: finalidade, categoria de titular, dados, fonte, compartilhamento, operador, localização, prazo, base legal, medidas de segurança e canal de direitos. Esse inventário antecede a produção. A equipe técnica não decide isoladamente a base legal.

14.4 Retenção

A retenção deve ser parametrizável e aprovada. Proposta inicial:

Dado	Retenção proposta	Observação
Avaliações e snapshots oficiais	ciclo corporativo + prazo definido por política	valor histórico e prestação de contas
Evidências	24 meses após fechamento, salvo política diversa	minimizar armazenamento
Rascunhos abandonados	90 dias	limpeza automática com aviso
Logs de auditoria	mínimo compatível com segurança e obrigações	incidentes pessoais: observar mínimo regulatório aplicável
Exportações temporárias	7 dias	link expirável
Conta inativa	preserva autoria; remove acesso	dados mínimos

Esses prazos não são decisão legal final. DPO e política corporativa devem ratificar.

14.5 Direitos e transparência

O aviso interno explica finalidade, dados, acesso, retenção, suporte e canal de privacidade. Solicitações de acesso/correção são encaminhadas ao processo corporativo. Correção de dado histórico não significa apagar a evidência de que o registro existiu; usa-se retificação ou adendo conforme a natureza.

14.6 Fornecedores e transferências

A contratação de BaaS, hospedagem, monitoramento e e-mail exige avaliação de DPA, suboperadores, região, transferências internacionais, exclusão, portabilidade, backups e resposta a incidentes. O desenho técnico deve permitir exportar dados e evidências em formato utilizável.

15. Trilha de auditoria, observabilidade e qualidade de dados

15.1 Trilha de auditoria

Eventos mínimos:

- login, logout, falha, MFA e recuperação;
- concessão/revogação de perfil;
- criação, submissão, devolução e aprovação;
- alteração de vínculo;
- criação/inativação/versionamento de indicador;
- acesso ou download de evidência sensível;
- exportação;
- adendo de registro aprovado;
- mudança de retenção;
- operação administrativa privilegiada.

O log contém quem, quando, onde aplicável, ação, objeto, resultado e correlação. Não deve guardar senha, token, arquivo ou texto sensível desnecessário. A trilha é append-only e tem acesso restrito.

15.2 Observabilidade técnica

Métricas: taxa de erro, latência, crashes, falhas de login, falhas de RLS, fila de sync, tempo de upload, storage, jobs, disponibilidade e versões instaladas. Alertas precisam de dono e ação. Telemetria não pode virar coleta excessiva de comportamento individual.

15.3 Qualidade de dados

Dimensões:

- completude;
- validade;
- unicidade;
- consistência;
- tempestividade;
- rastreabilidade;
- concordância com fonte.

O dashboard de qualidade mostra campos faltantes, valores fora de faixa, atrasos e discrepâncias. Dados não aprovados não entram em score oficial. Correções são registradas.

15.4 Reconciliação

Rotina diária verifica visitas previstas sem instância, submissões sem evidência, objetos no Storage sem metadado, metadados sem arquivo, planos vencidos e snapshots divergentes. Anomalias geram fila de correção, não ajuste silencioso.

16. Acessibilidade, usabilidade e experiência de campo

16.1 Referência

A aplicação web adotará WCAG 2.2 nível AA como referência [R6]. No mobile, os mesmos princípios se traduzem em rótulos acessíveis, ordem de foco, contraste, alvos adequados, suporte a leitor de tela, mensagens claras e não dependência exclusiva de cor.

16.2 Princípios de campo

- telas curtas e progressivas;
- salvamento automático de rascunho;
- indicação visível de offline e pendências;
- botões com rótulo, não apenas ícone;
- semáforo acompanhado de texto;
- confirmação para ação irreversível;
- erro próximo ao campo e orientação de correção;
- fotos com prévia, compressão e remoção;
- retorno claro após envio;
- continuidade da visita anterior sem excesso de informação.

16.3 Teste de usabilidade

Realizar tarefas representativas com usuários dos quatro perfis. Métricas: sucesso sem ajuda, tempo, erros, retrocessos, solicitações de ajuda e SUS. Observar ambiente real: luz, uma mão, rede oscilante, interrupções e pressão de tempo. O moderador não ensina durante a primeira tentativa.

16.4 Conteúdo e linguagem

Usar termos do trabalho, frases diretas e definições acessíveis. “Excluir indicador” deve aparecer como “Inativar para novas avaliações” quando houver histórico. Mensagens de permissão não revelam dados. Datas e períodos devem ser inequívocos. Evitar jargão técnico na interface.

17. Estratégia de testes e homologação

17.1 Pirâmide de testes

- 32. **Unitários:** score, semáforo, datas, regras de estado, validações e conflitos.
- 33. **Integração:** repositórios, banco, storage, auth, funções e jobs.
- 34. **RLS/segurança:** matriz completa de permitir/negar.
- 35. **E2E:** fluxos por perfil em web e Android prioritário.
- 36. **Offline:** outbox, retry, duplicação, conflito e atualização.
- 37. **Não funcionais:** desempenho, acessibilidade, restauração e observabilidade.
- 38. **UAT:** cenários reais aprovados pelo negócio.

17.2 Cobertura crítica

Cobertura percentual isolada não garante qualidade. São obrigatórios testes sobre: cálculo oficial; imutabilidade; autoaprovação; troca de vínculo; inativação de indicador; evidência privada; exportação; calendário; horário/fuso; sync; restauração; e todas as fronteiras de perfil.

17.3 Ambientes e dados

Desenvolvimento e homologação usam dados sintéticos. Produção não aceita usuários demo. Seeds são versionados. Cópia de produção para teste é proibida sem anonimização e aprovação. Cada ambiente possui chaves e buckets separados.

17.4 Homologação

O UAT deve ser roteirizado e registrado. Cada caso contém pré-condição, passos, resultado esperado, evidência e aprovador. Defeito recebe severidade. O Gate 3 exige 100% dos casos críticos aprovados, ausência de críticos/altos abertos e plano aceito para pendências médias.

17.5 Teste de restauração

Backup só é controle quando restaura. Antes do piloto, executar restauração em ambiente isolado, verificar contagem, integridade referencial, snapshots, usuários, logs e amostra de evidências. Registrar RTO e RPO observados.

18. DevSecOps, releases e manutenção

18.1 Fluxo Git

- branch principal protegida;
- branches curtas por mudança;
- pull request obrigatório;
- CI verde;
- revisão por outra pessoa em mudança crítica;
- commits e releases identificáveis;
- tags de versão;
- changelog e rollback.

18.2 Pipeline mínimo

39. instalação reprodutível com lockfile;
40. lint e formatação;
41. typecheck;
42. testes unitários e integração;
43. varredura de segredos e dependências;
44. build web e mobile;
45. testes de política do banco;
46. deploy em homologação;
47. aprovação manual;
48. produção e smoke test.

18.3 Banco como código

Mudanças de schema e RLS são migrations versionadas e revisadas. Alteração destrutiva exige plano de migração e rollback. O dashboard do provedor não deve ser a única fonte da estrutura. Seeds e funções têm versão no repositório.

18.4 Atualizações

Expo e React Native evoluem. O SDK 57 deve ser usado conforme documentação versionada [R11], e upgrades futuros devem ocorrer em janela planejada, com testes de câmera, documentos, storage, notificações e web. Dependência sem manutenção ou vulnerável gera plano de substituição.

18.5 Suporte e manutenção

Após o piloto, definir atendimento, on-call para incidentes, janela de manutenção, SLA, ownership e orçamento. O aplicativo não pode depender de uma única pessoa. Runbooks documentam deploy, rollback, usuário, backup, incidente e recuperação.

19. Continuidade, backup e recuperação

19.1 Objetivos

Proposta inicial:

- RPO de dados transacionais: até 24 horas, preferencialmente menor conforme plano contratado;
- RTO de serviço crítico: até 8 horas no piloto;
- evidências: recuperação coerente com metadados;
- rascunhos locais não sincronizados: responsabilidade compartilhada e aviso explícito.

19.2 Cenários

- indisponibilidade do BaaS;
- erro de migration;
- exclusão indevida;
- credencial comprometida;
- corrupção de evidência;
- falha do deploy web;
- perda de dispositivo;
- indisponibilidade de responsável técnico.

19.3 Controles

- backups automáticos conforme plano;
- export lógico periódico;
- cópia de configurações e migrations;
- inventário de buckets;
- teste trimestral de restauração após escala;
- rollback de aplicação;
- contatos e matriz de escalonamento;
- modo de contingência para registrar visita em rascunho local;
- reconciliação pós-incidente.

19.4 Encerramento do fornecedor

O plano de saída inclui exportar tabelas, objetos, metadados, usuários quando permitido, logs e documentação; validar integridade; migrar; revogar chaves; e obter confirmação de exclusão conforme contrato. Portabilidade deve ser testada antes de dependência crítica.

20. Desenho científico do piloto

20.1 Classificação

O piloto é um estudo prospectivo, longitudinal, de métodos mistos, em uma unidade. Ele avalia implementação e sinais de efetividade. Sem grupo controle e com amostra pequena, não permite afirmar causalidade forte. O relatório deve usar linguagem como “associado”, “observado” e “sugere”, evitando “provou”.

20.2 Objetivos

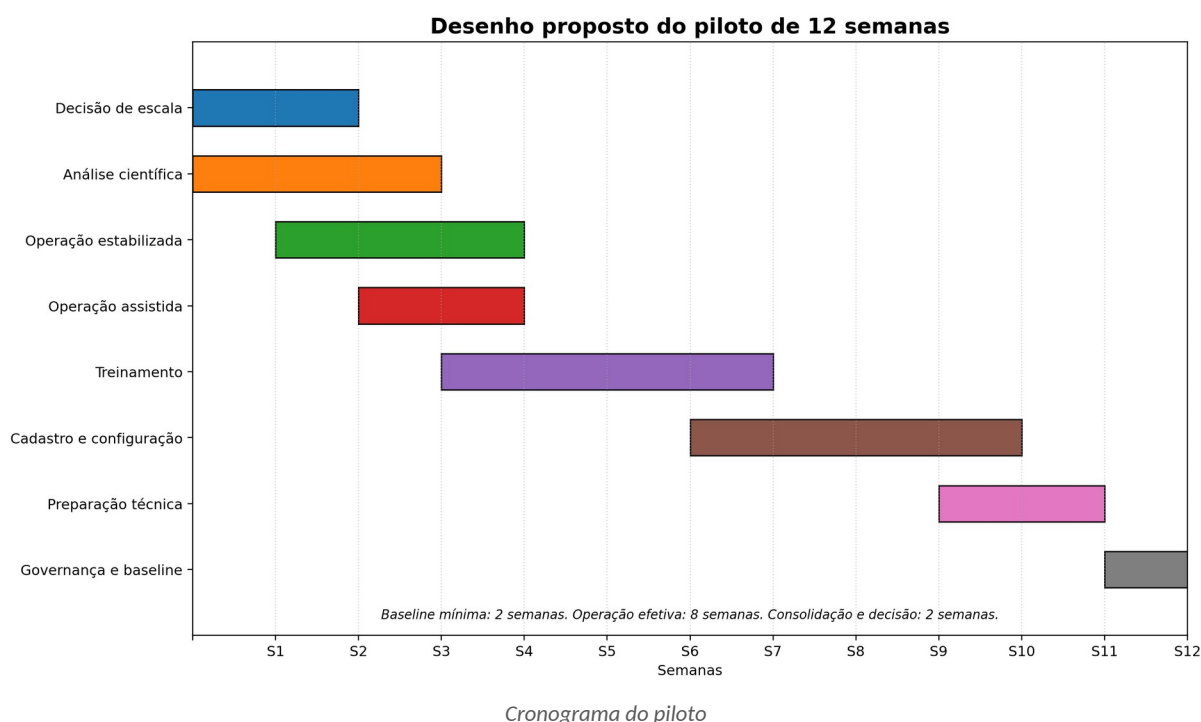
Primários

49. verificar viabilidade operacional;
50. verificar segurança, integridade e confiabilidade;
51. medir adoção e completude;
52. verificar se o fluxo reduz atraso, retrabalho ou perda de informação.

Secundários

- avaliar usabilidade por perfil;
- identificar ambiguidade nos indicadores;
- estimar carga de suporte;
- avaliar qualidade de planos;
- observar evolução de indicadores sem atribuir causalidade indevida;
- produzir requisitos para escala.

20.3 Fases



- **Semanas 1-2:** governança, baseline, configuração e teste final.
- **Semanas 3-4:** treinamento e operação assistida.
- **Semanas 5-10:** operação estabilizada.
- **Semanas 11-12:** análise, entrevistas e decisão.

20.4 Unidade de análise

Usuários, visitas, auditorias, operações e planos. Resultados de negócio devem ser interpretados no nível apropriado. Não se deve multiplicar artificialmente a amostra tratando cada campo como observação independente.

20.5 Fontes

- logs do sistema;

- registros aprovados;
- baseline do processo anterior;
- questionário SUS;
- entrevistas semiestruturadas;
- diário de incidentes e suporte;
- amostra de qualidade revisada por especialistas.

20.6 Ética da avaliação

Participantes devem saber o que será medido e para que finalidade. Métricas de uso não devem ser convertidas em avaliação laboral secreta. Relatórios do piloto agregam resultados sempre que possível. Comentários qualitativos são anonimizados no relatório executivo.

21. Hipóteses, métricas e critérios de sucesso

21.1 Hipóteses

ID	Hipótese	Métrica principal
H1	O fluxo é utilizável no trabalho real	sucesso de tarefas, SUS, ajuda solicitada
H2	A centralização aumenta completude e tempestividade	campos completos e visitas no prazo
H3	A validação reduz registros inconsistentes	devoluções por erro e discrepâncias
H4	O histórico melhora acompanhamento de ações	ações revisadas na visita seguinte
H5	O offline controlado evita perda e duplicação	taxa de sync, duplicatas e falhas
H6	A governança de acesso protege escopos	testes RLS e incidentes
H7	A solução reduz tempo de consolidação	minutos/horas antes e depois

21.2 Critérios obrigatórios de segurança e integridade

Todos devem ser atendidos:

- autenticação individual;
- zero falha crítica ou alta de autorização sem aceite formal;
- 100% das avaliações aprovadas imutáveis;
- 100% das evidências obrigatórias privadas e recuperáveis;
- restauração de backup aprovada;
- trilha de auditoria para eventos críticos;
- zero incidente grave de privacidade;
- nenhum segredo privilegiado no cliente ou repositório;
- segregação de ambientes;
- aprovação de Segurança e Privacidade.

21.3 Critérios propostos de implementação

Indicador	Limiar proposto
Usuários ativos semanais / elegíveis	>= 85%
Visitas previstas concluídas no prazo	>= 90%
Completude dos obrigatórios	>= 95%
Sincronizações concluídas em 24 h	>= 99%
Registros duplicados por falha	< 0,5%
SUS mediano	>= 75
Tarefas críticas concluídas sem ajuda	>= 85%
Avaliações devolvidas por erro de sistema	< 5%
Planos críticos com responsável e prazo	100%
Ações revisadas no ciclo seguinte	>= 90%

21.4 Regra de decisão

- **Escalar:** todos os critérios obrigatórios e pelo menos 7 dos 10 critérios de implementação, sem tendência de risco crescente.
- **Escalar condicionado:** obrigatórios atendidos, 5-6 critérios de implementação, com correções de baixo risco e prazo claro.
- **Repetir piloto:** obrigatórios atendidos, mas adoção ou processo insuficientes para conclusão.
- **Interromper:** falha crítica de segurança, privacidade, perda de dados, rejeição operacional persistente ou ausência de patrocínio.

Os limiares devem ser aprovados antes da coleta para evitar ajustá-los após observar o resultado.

22. Plano de análise e rigor metodológico

22.1 Preparação

Publicar protocolo interno antes do piloto: objetivos, métricas, fórmulas, exclusões, períodos e critérios. Congelar versão do instrumento durante a fase estabilizada, exceto correção crítica documentada.

22.2 Estatística descritiva

Para taxas: numerador, denominador e período. Para tempo: mediana, intervalo interquartil e distribuição, pois tempos operacionais costumam ser assimétricos. Para scores: média e mediana, além de dispersão. Sempre informar dados faltantes.

22.3 Comparação pré/pós

Quando houver medidas comparáveis, usar pares por operação ou usuário. Apresentar diferença absoluta e relativa, intervalo de confiança quando razoável e tamanho de efeito. Com amostra pequena, privilegiar gráficos de série temporal e interpretação cautelosa; testes de significância não devem substituir relevância operacional.

22.4 Run charts e processo

Plotar semanalmente adoção, pontualidade, completude, devoluções e sync. Sinais de mudança sustentada são mais úteis que uma média final isolada. Anotar treinamento, falha de rede, release e feriado.

22.5 Qualitativo

Entrevistas com amostra dos quatro perfis exploram utilidade, carga, clareza, confiança, ética e sugestões. Duas pessoas podem codificar temas principais quando possível. O relatório traz padrões e exemplos anonimizados, não frases identificáveis sem consentimento.

22.6 Viés e limitações

- efeito novidade;
- viés de seleção da unidade piloto;
- mudança de comportamento por observação;
- melhora por treinamento, não apenas tecnologia;
- sazonalidade;
- metas alteradas;
- amostra pequena;
- dependência de autorrelato;
- avaliador e gestor serem a mesma pessoa.

O relatório final inclui seção explícita de limitações e não generaliza automaticamente para toda a organização.

23. Treinamento, gestão da mudança e suporte

23.1 Estratégia

Treinamento deve ensinar processo, não apenas botões. Cada perfil recebe roteiro específico, ambiente de homologação, casos práticos e material curto. O GC pratica uma visita offline; o Coordenador devolve e aprova; o Regional interpreta painel; o Administrador cria usuário e inativa indicador em cenário controlado.

23.2 Conteúdo mínimo

- finalidade e ética;
- credencial individual e MFA;
- escopo de acesso;
- agenda e estados;
- evidências sem dados pessoais;
- diagnóstico e ação verificável;
- envio, devolução e aprovação;
- offline e sincronização;
- incidentes e suporte;
- leitura correta dos indicadores.

23.3 Superusuários

Designar um Coordenador e um GC como referências locais, sem conceder privilégio técnico indevido. Eles ajudam na adoção, coletam feedback e identificam bloqueios. Decisões de configuração permanecem com governança.

23.4 Suporte durante o piloto

- canal único de suporte;
- triagem por severidade;
- registro de causa e resolução;
- plantão reforçado nas duas primeiras semanas;
- FAQ atualizado;
- reunião curta semanal;
- relatório de tickets por categoria.

23.5 Resistência e carga

A adoção falha quando o aplicativo duplica registros ou aumenta tempo sem retorno. Durante o piloto, eliminar planilhas paralelas apenas quando o novo fluxo estiver estável e autorizado. Perguntar não só “gostou?”, mas “qual tarefa foi substituída, qual foi criada e quanto tempo exigiu?”.

24. Plano de implementação por fases

24.1 Visão geral

Prazo é estimativa de planejamento, não compromisso contratual. A construção pode durar 14 a 18 semanas antes do piloto, conforme equipe, aprovações e integração de identidade.

Fase	Entregas	Gate
0. Fundação	decisões, RACI, backlog, ambientes, ADR de arquitetura	G0
1. Dados e privacidade	modelo, inventário, retenção, DPA, migrations iniciais	G1
2. Identidade e acesso	Auth, perfis, escopos, RLS, logs	G2
3. Núcleo operacional	agenda, visitas, auditoria, indicadores, ações	parcial G3
4. Evidências e offline	storage privado, outbox, conflitos, uploads	parcial G3
5. Validação e dashboards	aprovação, snapshots, relatórios	G3
6. Hardening	segurança, acessibilidade, desempenho, restauração	G3/G4
7. Piloto	baseline, treinamento, 8 semanas de uso, análise	G5
8. Escala	correções, integrações, múltiplas unidades	novo programa

24.2 Fase 0

- aprovar nomenclatura AAPEX/AACE;
- nomear PO, técnico, Segurança e Privacidade;
- definir unidade e participantes;
- decidir SSO ou Auth;
- confirmar inexistência de dados reais no protótipo;
- criar ambientes e branch de trabalho;
- congelar baseline do código.

24.3 Fase 1

- validar 24 temas e 12 indicadores;
- aprovar modelo de dados;
- registrar operações de tratamento;
- definir política de evidência e retenção;
- aprovar fornecedor e região;
- criar migrations, seeds e testes de integridade.

24.4 Fase 2

- implementar autenticação;
- perfis e escopos;
- ciclo de acesso;
- RLS e testes negativos;
- logs e MFA;
- remover senha demo e atalhos.

24.5 Fases 3 a 5

Refatorar telas para repositórios, implementar workflow, versionamento, snapshots, storage, offline, dashboards e export. Cada módulo entra com testes e UAT. Não aguardar o fim para testar permissões.

24.6 Fase 6

- pentest ou avaliação independente proporcional;
- acessibilidade;
- teste de restauração;
- performance;
- ensaio completo do piloto;

- treinamento e runbooks;
- aprovação do Gate 4.

25. Custos, capacidade e sustentabilidade

25.1 Princípio de custo total

O custo não é apenas assinatura do BaaS. Inclui desenvolvimento, segurança, suporte, treinamento, privacidade, monitoramento, armazenamento de evidências, manutenção e evolução. Free tier pode servir a desenvolvimento, mas produção corporativa não deve depender de pausa por inatividade, limites não contratados ou ausência de suporte adequado.

25.2 Categorias

Categoria	Driver
Desenvolvimento	escopo, integração, offline, testes
Plataforma	usuários, banco, compute, egress, storage
Evidências	quantidade, tamanho, retenção e download
Identidade	SSO, MFA, diretório
Observabilidade	eventos, retenção, alertas
Segurança	revisão, pentest, gestão de vulnerabilidade
Operação	suporte, administração, treinamento
Continuidade	backups, export e restauração

25.3 Modelo de estimativa

Antes do Gate 0, calcular três cenários: piloto, expansão regional e escala corporativa. Para cada um, estimar usuários ativos, visitas/mês, avaliações, evidências por visita, tamanho médio, retenção, consultas e exportações. Aplicar margem de 30% a volumes. Preços devem ser consultados no momento da contratação, pois mudam.

25.4 Capacidade de equipe

Mínimo recomendado na construção: PO com disponibilidade real, desenvolvedor full-stack/mobile, revisão técnica independente, apoio de Segurança e Privacidade e usuários de negócio para UAT. Uma pessoa pode acumular funções, mas revisão de segurança e aprovação de negócio não devem depender exclusivamente do autor do código.

26. Registro de riscos

ID	Risco	Prob.	Impacto	Resposta
R01	Escopo crescer durante piloto	Alta	Alta	congelar escopo e usar change control
R02	Indicadores ambíguos	Alta	Alta	calibração e versionamento
R03	RLS incompleta	Média	Crítica	testes automatizados por perfil e revisão independente
R04	Evidência com dado de cliente	Média	Alta	política, treinamento, recorte e revisão
R05	Rede instável	Alta	Média	outbox, upload retomável e feedback
R06	Compartilhamento de credencial	Média	Alta	conta individual, MFA e monitoramento
R07	Baixa adoção por duplicidade	Média	Alta	eliminar processo paralelo por etapa
R08	Sobrescrita histórica	Média	Crítica	snapshots e adendos
R09	Dependência de uma pessoa	Alta	Alta	documentação, revisão e runbooks
R10	Free tier inadequado	Média	Alta	plano de produção e monitoramento de limites
R11	Custo de storage crescer	Média	Média	compressão, retenção e forecast
R12	Ranking gerar constrangimento	Média	Alta	restrição, agregação e governança ética
R13	Mudança de meta invalidar comparação	Alta	Média	vigência e versão
R14	Falha de backup	Baixa	Crítica	teste de restauração
R15	Atualização Expo quebrar captura	Média	Média	upgrades planejados e regressão
R16	Dados fictícios entrarem em produção	Média	Alta	seeds separados e bloqueio de ambiente
R17	Falta de patrocinador local	Média	Alta	Gate 4 exige responsável e agenda
R18	Sobrecarga do Coordenador	Média	Alta	estimar fila e SLA no piloto
R19	Telemetria excessiva	Baixa	Alta	minimização e revisão de Privacidade
R20	Exportação indevida	Média	Alta	permissão, log, expiração e marcação
R21	Causalidade superestimada	Alta	Média	relatório com limitações
R22	Dado local após revogação	Média	Alta	expiração, logout remoto e limpeza
R23	Dois dispositivos gerarem conflito	Média	Média	lock otimista e revisão explícita
R24	Aprovação automática por pressão	Média	Alta	proibir lote no piloto e auditar tempo
R25	Falta de base legal definida	Baixa	Crítica	bloquear G1

26.1 Critérios de interrupção

Interromper ou pausar imediatamente em caso de acesso entre escopos, evidência pública, perda de avaliação aprovada, chave privilegiada exposta, incidente relevante de dados pessoais, impossibilidade de restaurar ou risco operacional não controlado. A pausa não é fracasso; é controle de dano e aprendizagem.

27. Roadmap de produto e escala

27.1 Releitura do roadmap original

- **V1.0 Estrutura:** autenticação real, dados centrais, perfis e operação básica.
- **V1.1 Agenda:** calendário configurável e exceções.
- **V1.2 Gestão Assistida:** indicadores, diagnóstico e retroalimentação.
- **V1.3 Governança:** administração, versões, logs, privacidade e validação.
- **V1.4 Indicadores Inteligentes:** regras, alertas, tendência e qualidade.
- **V1.5 Boas Práticas:** moderação, replicabilidade e aprendizagem.
- **V2.0 Business Intelligence:** snapshots, modelos semânticos, export e painéis corporativos.

O código atual já simula partes de V1.0-V1.2, mas a versão corporativa deve ser numerada pela maturidade real, não apenas por telas.

27.2 Escala em ondas

Onda 0 - Piloto

Uma unidade, quatro perfis, suporte próximo, sem integração externa.

Onda 1 - Expansão controlada

Três a cinco unidades, revisão de capacidade, treinamento de multiplicadores, políticas consolidadas e dashboard regional.

Onda 2 - Regional completa

Todas as unidades PR/SC, SSO corporativo, suporte formal, BI e revisão de custos.

Onda 3 - Multirregional

Modelo multi-região, segregação, parametrização, governança central e local, benchmark contextualizado e continuidade reforçada.

27.3 Gate de escala

Cada onda exige: resultado da anterior, capacidade de suporte, custo aprovado, segurança, privacidade, treinamento e qualidade de dados. Não escalar para “resolver depois” problemas de acesso, histórico ou evidência.

28. Decisões pendentes para aprovação corporativa

ID	Decisão	Dono proposto	Prazo
P01	Nome oficial do produto e relação AAPEX/AACE	Negócio	G0
P02	Identidade: SSO, domínio de e-mail ou Auth	TI/Segurança	G0
P03	Pessoa(s) com perfil Administrador	Patrocinador	G0
P04	Coordenador pode executar visita?	Negócio	G0
P05	Validade dos 24 temas e 12 indicadores	Negócio	G1
P06	Regra exata de terça-feira e rodízio	Regional	G1
P07	Base legal e aviso de privacidade	DPO/Jurídico	G1
P08	Evidências permitidas e retenção	DPO/Negócio	G1
P09	Fornecedor, região e plano contratado	TI/Compras	G1
P10	MFA para GCs	Segurança/Negócio	G2
P11	Ranking nominal pós-piloto	Comitê/Ética	G5
P12	Ferramenta de monitoramento	TI/Segurança	G2
P13	SLA e equipe de suporte	Patrocinador	G4
P14	Critérios finais de sucesso	Comitê	antes do baseline
P15	Integrações e BI após piloto	Patrocinador	G5

A ausência de decisão deve aparecer como bloqueio, não ser preenchida por suposição escondida.

29. Recomendação executiva final

Aprovar o AAPEX/AACE como programa de transformação operacional apoiado por tecnologia, e não como simples aplicativo de checklist. Aprovar a preservação da interface útil e a substituição da camada de dados demonstrativa. Autorizar a arquitetura Expo + PostgreSQL/Supabase + Vercel como referência para detalhamento, condicionada a Segurança, Privacidade e Compras. Formalizar Administrador e Regional como perfis distintos. Manter a regra de que somente Administrador governa indicadores e que histórico não é apagado.

Antes de codificar novas funcionalidades, concluir P01-P10, criar ambientes separados, remover credenciais demo e congelar o baseline. Implementar primeiro identidade, RLS, modelo versionado e trilha; depois migrar telas. Não iniciar piloto sem restauração testada, UAT e critérios de sucesso aprovados.

Executar piloto de 12 semanas em uma unidade, com baseline, suporte assistido, métodos mistos e relatório que declare limitações. Proibir ranking individual público e uso punitivo automático. Ao final, decidir entre escalar, escalar condicionado, repetir ou encerrar com base nos gates.

O maior risco não é o aplicativo “não funcionar”; é parecer funcionar enquanto identidade, histórico, evidências e permissões permanecem frágeis. O maior ativo é já existir uma experiência funcional que pode ser consolidada sem reconstrução total. Este Masterplan organiza a passagem entre esses dois estados.

Anexo A. Matriz RACI

Legenda: R = responsável por executar; A = accountable/aprovador; C = consultado; I = informado.

Atividade	Patrocinador	PO	Técnico	Admin	Regional	Coord.	GC	Segurança	DPO
Aprovar escopo	A	R	C	I	C	C	I	C	C
Definir requisitos	I	A/R	C	C	C	C	C	I	I
Arquitetura	I	C	A/R	I	I	I	I	C	C
Modelo de dados	I	A	R	C	C	C	I	C	C
Base legal/retenção	I	C	C	I	I	I	I	C	A/R
RLS e segurança	I	I	R	I	I	I	I	A	C
Configurar indicadores	I	A	C	R	C	C	I	I	I
Executar visitas	I	I	I	I	I	C	R	I	I
Validar avaliações	I	I	I	I	I	A/R	I	I	I
Monitorar piloto	A	R	C	C	R	R	C	C	C
Responder incidente	I	C	R	I	I	I	I	A	A/C
Decidir escala	A	R	C	I	C	C	I	C	C

Anexo B. Matriz detalhada de permissões

Recurso / operação	Admin	Regional	Coordenador	GC	Regra adicional
Usuário - criar	Permitir	Negar	Negar	Negar	função server-side
Usuário - suspender	Permitir	Solicitar	Negar	Negar	log e motivo
Escopo - atribuir	Permitir	Consultar	Negar	Negar	vigência
Operação - criar	Permitir	Solicitar	Consultar	Consultar	conforme governança
Operação - ver	escopo admin	região	atribuídas	atribuídas	RLS
Template - criar versão	Permitir	Consultar	Propor	Negar	não altera passado
Indicador - inativar	Permitir	Negar	Negar	Negar	se usado, sem delete
Visita - criar	autorizado	Negar	configurável	atribuída	calendário/escopo
Visita - editar rascunho	se autor	Negar	se autor	se autor	versão esperada
Visita - enviar	se autor	Negar	se autor	se autor	completude
Avaliação - aprovar	fora da rotina	escalação	permitir	negar	nunca própria
Avaliação - adendo	administrar fluxo	solicitar	solicitar	solicitar	segundo aprovador
Evidência - upload	conforme origem	negar	conforme origem	conforme origem	bucket privado
Evidência - download	escopo	região	escopo	própria/escopo	URL curta
Plano - criar	permitir	permitir	permitir	permitir na visita	escopo
Plano - concluir	conforme vínculo	supervisionar	permitir	permitir se responsável	evidência
Boa prática - propor	permitir	permitir	permitir	permitir	sem dados pessoais
Boa prática - publicar	administrar	consultar	moderar	negar	aprovação
Dashboard	completo autorizado	região	equipe	próprias operações	dados oficiais
Ranking nominal	restrito	restrito	equipe	negar	desativado no piloto
Exportação	controlada	região	escopo	relatório próprio	log e expiração
Audit log	completo restrito	eventos gerenciais	escopo	próprias ações	sem edição

Anexo C. Dicionário de dados inicial

Campo	Entidade	Tipo	Obrigatório	Finalidade	Classificação
user_id	users	UUID	Sim	identidade técnica	interno
display_name	users	texto	Sim	identificação operacional	dado pessoal
corporate_email	users	texto	Sim	login/contato	dado pessoal
role_code	user_scopes	enum	Sim	autorização	interno
unit_id	user_scopes	UUID	Sim	delimitar acesso	interno
valid_from/to	user_scopes	data	Sim	histórico de vínculo	interno
visit_type	visits	enum	Sim	semanal/mensal	interno
scheduled_at	visits	data/hora	Sim	agenda	interno
status	visits	enum	Sim	workflow	interno
template_version_id	evaluations	UUID	Sim	verdade histórica	interno
submitted_at	evaluations	data/hora	Não	SLA e histórico	interno
approved_at	evaluations	data/hora	Não	oficialização	interno
answer_value	evaluation_answers	variável	Sim	avaliação	interno
score_component	evaluation_answers	decimal	Sim	cálculo	interno
indicator_version_id	measurements	UUID	Sim	definição vigente	interno
target_value	measurements	decimal	Sim	meta	interno/confidencial
actual_value	measurements	decimal	Sim	resultado	interno/confidencial
evidence_path	evidence_files	texto	Sim	localizar objeto	segredo operacional
sha256	evidence_files	texto	Sim	integridade	interno
mime_type	evidence_files	texto	Sim	validação	interno
retention_until	evidence_files	data	Sim	descarte	interno
diagnosis_text	diagnoses	texto	Sim	causa/impacto	interno/confidencial
action_description	action_plans	texto	Sim	melhoria	interno
action_owner_id	action_plans	UUID	Sim	responsabilização	dado pessoal interno
due_date	action_plans	data	Sim	acompanhamento	interno
validation_reason	validations	texto	depende	devolução/aprovação	interno
audit_event	audit_logs	enum	Sim	rastreabilidade	restrito
ip/device metadata	audit_logs	mínimo	depende	segurança	dado pessoal técnico

Anexo D. Catálogo mínimo de testes de aceite

ID	Cenário	Resultado esperado	Criticidade
T01	GC tenta acessar operação não atribuída	negado no servidor	Crítica
T02	Coordenador tenta aprovar própria visita	negado	Crítica
T03	Chave de service role buscada no bundle	inexistente	Crítica
T04	URL de evidência copiada após expiração	acesso negado	Alta
T05	Indicador usado é "excluído"	fica inativo; histórico íntegro	Crítica
T06	Template muda com rascunho aberto	rascunho mantém versão	Alta
T07	Avaliação aprovada é editada	bloqueado; somente adendo	Crítica
T08	Dois cliques enviam visita	uma submissão	Alta
T09	Rede cai durante upload	retoma sem corromper	Alta
T10	Token expira offline	operação fica pendente e reautentica	Alta
T11	Usuário perde vínculo antes do sync	servidor nega e sinaliza revisão	Alta
T12	Feriado na terça	agenda aplica exceção aprovada	Média
T13	Item vermelho sem plano	envio bloqueado	Alta
T14	Evidência obrigatória ausente	envio bloqueado	Alta
T15	Score cliente difere do servidor	aprovação bloqueada e alerta	Crítica
T16	Exportação por GC	apenas escopo permitido	Alta
T17	Regional abre dashboard	vê região e não configuração	Alta
T18	Admin inativa usuário	acesso revogado; autoria preservada	Alta
T19	Restore de backup	dados e amostra de arquivos íntegros	Crítica
T20	Leitor de tela navega formulário	rótulos e ordem corretos	Alta
T21	Semáforo sem cor	texto comunica estado	Média
T22	Aplicativo atualiza com outbox	pendências preservadas	Alta
T23	Arquivo com MIME inválido	rejeitado	Alta
T24	Upload duplicado	hash/idempotência evita duplicação	Média
T25	Log de aprovação	autor, horário, objeto e resultado presentes	Alta
T26	Rascunho abandonado	expira conforme política	Média
T27	Boa prática com dado pessoal	moderação bloqueia publicação	Alta
T28	Ranking no perfil GC	indisponível no piloto	Alta
T29	Versão exibida	corresponde ao build	Baixa
T30	Usuário demo em produção	inexistente	Crítica

Anexo E. Instrumentos do piloto

E.1 Questionário SUS

Aplicar a versão validada/autorizada do System Usability Scale com dez itens e escala de cinco pontos, após período mínimo de uso. Calcular conforme protocolo. Não alterar redação sem justificar comparabilidade. Complementar com duas perguntas abertas: “qual tarefa ficou mais fácil?” e “qual tarefa ficou mais difícil?”.

E.2 Roteiro de entrevista

53. Descreva a última visita realizada com o aplicativo.
54. Em que momento houve dúvida ou interrupção?
55. O sistema recuperou corretamente a visita anterior?
56. A exigência de evidência ajudou ou criou trabalho sem valor?
57. O que você entende por avaliação aprovada?
58. Como foi trabalhar sem conexão?
59. Alguma informação pareceu excessiva ou sensível?
60. O dashboard mudou alguma decisão?
61. Houve medo de exposição por ranking ou score?
62. Qual mudança é indispensável antes de escalar?

E.3 Checklist de observação

- concluiu login sem ajuda;
- identificou operação correta;
- iniciou visita prevista;
- preencheu indicador;
- anexou evidência;
- entendeu item vermelho;
- criou ação com responsável/prazo;
- percebeu estado offline;
- enviou e reconheceu confirmação;
- localizou pendência anterior.

E.4 Diário de suporte

Campos: data, perfil, versão, contexto, categoria, severidade, descrição, workaround, causa, tempo de resolução, necessidade de mudança e vínculo com incidente.

Anexo F. Fórmulas de KPIs

KPI	Fórmula	Observação
Adoção semanal	usuários com ação significativa / usuários elegíveis	login isolado não conta
Pontualidade	visitas concluídas na janela / visitas previstas válidas	excluir cancelamento legítimo separadamente
Compleitude	campos obrigatórios válidos / campos obrigatórios esperados	após aprovação
Taxa de devolução	avaliações devolvidas / submetidas	segmentar por motivo
Fechamento no prazo	ações concluídas até prazo / ações vencidas no período	considerar reabertura
Sync em 24 h	operações sincronizadas em 24 h / operações criadas offline	medir por evento
Duplicação	registros duplicados confirmados / registros criados	causa técnica
Tempo de consolidação	tempo ativo para preparar relatório	baseline comparável
Cobertura de evidência	itens que exigem evidência com arquivo válido / itens exigidos	não apenas URI
Evolução	valor atual - valor de baseline	usar versão comparável

F.1 Regras

Denominadores devem ser definidos antes da análise. Dados faltantes não viram zero automaticamente. Mudança de versão do indicador segmenta a série. Resultados com menos de cinco observações devem ser apresentados com cautela e sem ranking.

Anexo G. Definition of Done

Uma história só está concluída quando:

- requisito e critério de aceite estão aprovados;
- código está tipado, revisado e no padrão;
- testes unitários e integração passam;
- RLS foi testada quando há dados;
- estados de carregamento, vazio, erro e offline existem;
- acessibilidade básica foi verificada;
- logs não contêm dados indevidos;
- migration e rollback foram avaliados;
- documentação e changelog foram atualizados;
- ambiente de homologação foi testado;
- PO aceitou;
- não há vulnerabilidade crítica/alta conhecida sem aceite.

Uma fase só está concluída quando suas histórias, evidências de teste, riscos e runbooks estão consolidados e o gate correspondente foi formalmente decidido.

Anexo H. Modelo de ADR

ADR-XXX - Título Status: proposto / aceito / substituído **Data:** **Decisores:**

Contexto

Qual problema e quais restrições motivam a decisão?

Opções consideradas

- 63. opção A;
- 64. opção B;
- 65. opção C.

Decisão

Qual opção foi escolhida e por quê?

Consequências positivas

Benefícios esperados.

Consequências negativas e riscos

Custos, lock-in, limitações e mitigação.

Evidências e revisão

Como testar a decisão e quando revisá-la.

Anexo I. Glossário

Termo	Definição no projeto
AAPEX	programa de excelência descrito no plano-base
AACE	canal e nome do aplicativo AACE Excelência Mobile
GC	Gerente de Canal
RBAC	autorização baseada em papéis
ABAC	autorização complementada por atributos/escopo
RLS	política de segurança por linha no PostgreSQL
Snapshot	representação imutável do resultado oficial em um momento
Seed	conteúdo inicial para configuração, não dado real de produção
Outbox	fila local de operações aguardando sincronização
Idempotência	garantia de que repetir a mesma operação não duplica o efeito
RPO	perda máxima de dados tolerável medida no tempo
RTO	tempo-alvo de restauração do serviço
UAT	homologação pelo usuário/negócio
SUS	escala padronizada de usabilidade
ADR	registro de decisão arquitetural
DPO/Encarregado	função de proteção de dados conforme estrutura corporativa
Evidência	arquivo ou registro que sustenta uma observação ou conclusão
Adendo	correção ou complemento posterior sem apagar o registro original

Anexo J. Referências técnicas e normativas

- [R1] Autoridade Nacional de Proteção de Dados. *Guia Orientativo sobre Segurança da Informação para Agentes de Tratamento de Pequeno Porte*. Disponível no portal oficial da ANPD/Gov.br.
- [R2] Autoridade Nacional de Proteção de Dados. *Guia Orientativo para Definições dos Agentes de Tratamento de Dados Pessoais e do Encarregado*, versão 2.0 e materiais correlatos.
- [R3] National Institute of Standards and Technology. *The NIST Cybersecurity Framework (CSF) 2.0*, NIST CSWP 29, 2024.
- [R4] OWASP Foundation. *Application Security Verification Standard - ASVS 5.0.0*.
- [R5] OWASP Foundation. *Mobile Application Security Verification Standard - MASVS* e materiais MASTG.
- [R6] World Wide Web Consortium. *Web Content Accessibility Guidelines - WCAG 2.2*, W3C Recommendation.
- [R7] ISO/IEC 27001:2022. *Information security, cybersecurity and privacy protection - Information security management systems - Requirements*.
- [R8] Supabase Documentation. *Postgres Row Level Security*.
- [R9] Supabase Documentation. *Storage - private files and fine-grained access control*.
- [R10] Supabase Documentation. *Multi-Factor Authentication*.
- [R11] Expo Documentation. *Expo SDK 57 reference and versioned APIs*.
- [R12] Supabase Documentation. *Resumable Uploads using TUS*.
- [R13] Autoridade Nacional de Proteção de Dados. *Regulamento e orientações sobre Comunicação de Incidente de Segurança*, Resolução CD/ANPD nº 15/2024.

Fontes internas

- 66. *AAPEX - Plano Master v1.0 - Programa de Excelência da Claro Empresas - Regional Paraná e Santa Catarina - Canal AACE*.
- 67. *AUDITORIA_TECNICA_PRELIMINAR_AACE_V2*.
- 68. Decisões fornecidas para este Masterplan: quatro perfis com login, objetivo de implantação corporativa e piloto em uma unidade.

Anexo K. Checklist para autorização do piloto

Negócio

- ☐ Unidade piloto e operações definidas.
- ☐ Usuários, papéis e responsáveis confirmados.
- ☐ 24 temas e 12 indicadores validados ou substituídos.
- ☐ Rotina, feriados, rodízio e SLA aprovados.
- ☐ Critérios de sucesso assinados.
- ☐ Processo paralelo e plano de transição definidos.

Tecnologia

- ☐ Ambientes separados.
- ☐ CI/CD e rollback.
- ☐ Auth individual.
- ☐ RLS testada.
- ☐ Storage privado.
- ☐ Offline e sync testados.
- ☐ Backup restaurado.
- ☐ Monitoramento ativo.

Segurança e privacidade

- ☐ Threat model revisado.
- ☐ Sem vulnerabilidade crítica/alta aberta.
- ☐ Inventário de tratamento.
- ☐ Base legal e aviso aprovados.
- ☐ Retenção definida.
- ☐ DPA e região avaliados.
- ☐ Playbook de incidente.
- ☐ Evidências sem dados indevidos.

Operação

- ☐ Treinamento realizado.
- ☐ Canal de suporte testado.
- ☐ Superusuários designados.
- ☐ Baseline coletada.
- ☐ Dispositivos e conectividade verificados.
- ☐ Termo de início do piloto aprovado.